Social Engineering and Bluetooth Device Exploitation for Command Execution via AI-Generated Voice

Imad Ali Syed, Jay Jariwala, Muhaiminul Islam
M.S. in Cybersecurity, City College of New York, New York, USA

Project Report for: Penetration Testing and Ethical Hacking
Instructor: Prof. Ihab Darwish
Institution: City College of New York
Date: May 25, 2025

Abstract
Bluetooth-enabled devices are increasingly integrated into personal and home environments, offering convenience but also exposing significant security vulnerabilities. This project explores a novel attack that leverages two converging technologies: insecure Bluetooth audio device pairing and AI-generated voice impersonation. We detail a full-cycle attack from device discovery and connection to payload delivery and result analysis. We present an implementation that targets commonly available Bluetooth earbuds, utilizing realistic synthesized voice commands to control a connected smart environment. This report delves deeply into Bluetooth versions, pairing protocols, and security levels, and emphasizes the critical importance of authentication and encryption in voice and communication systems.

1. Introduction

The rapid adoption of smart technologies has transformed the way we interact with our environments. Voice assistants, smart TVs, IoT appliances, and connected Bluetooth peripherals now dominate many homes. However, this interconnectedness introduces an expanded attack surface, particularly for devices with low authentication requirements.

Bluetooth remains one of the most used wireless communication protocols, especially in personal audio devices. Despite improvements in newer Bluetooth versions, many devices still rely on outdated security modes or prioritize ease of connectivity over robustness. Coupled with the explosive advancement in artificial intelligence, particularly in text-to-speech (TTS) and voice cloning, attackers can now simulate voice commands with high realism.

This project explores how an attacker can exploit such a combination to issue unauthorized voice commands through a Bluetooth audio path. Once transmitted, these voice commands can be interpreted as legitimate by smart assistants (like Siri, Alexa, or Google Assistant), leading to actions that the user did not authorize.

2. Objective

The objectives of this project include:

Demonstrating how certain Bluetooth devices can be connected to without user interaction due to insecure pairing mechanisms.

Illustrating how AI-generated voice cloning can be used to bypass voice recognition and trigger trusted systems.

Analyzing the technical characteristics of different Bluetooth protocols and pairing mechanisms.

Performing a simulated brute-force attack to model potential weaknesses in PIN-based pairing.

Highlighting ethical concerns and proposing realistic mitigation strategies to counter such emerging threats.

3. Literature Review

3.1 Bluetooth Technology Overview

Bluetooth is a short-range wireless communication protocol commonly used to connect devices such as headphones, speakers, keyboards, and smart home equipment. It operates in the 2.4 GHz ISM band and uses frequency hopping to minimize interference.

There are two major types of Bluetooth:

- **Bluetooth Classic (BR/EDR):** Supports higher data rates and is used primarily for audio and data transfer.
- **Bluetooth Low Energy (BLE):** Designed for low-power applications, commonly used in fitness trackers, sensors, and other IoT devices.

The Bluetooth protocol stack consists of several layers:

- **L2CAP (Logical Link Control and Adaptation Protocol):** Manages data segmentation and reassembly.
- **RFCOMM:** Provides serial communication over Bluetooth.
- **SDP (Service Discovery Protocol):** Allows devices to discover available services on a remote device.
- **A2DP (Advanced Audio Distribution Profile):** Used for streaming high-quality audio.
- **HFP (Hands-Free Profile):** Used in hands-free voice communication scenarios, such as with car systems or headsets.

These layers work together to manage connections, data flow, service negotiation, and profile-specific functions.

3.2 Bluetooth Pairing and Security Modes

Bluetooth devices use different pairing methods depending on their capabilities and use cases. These pairing modes determine how securely two devices exchange encryption keys and establish a connection.

Common Bluetooth pairing modes include:

- **Just Works:** No authentication or user interaction. Used by devices with no input/output capabilities. Vulnerable to man-in-the-middle (MITM) attacks.
- **Legacy PIN Pairing:** Uses a 4-digit or fixed PIN. Still found in some older devices. Susceptible to brute-force attacks.
- **Numeric Comparison:** Displays a number on both devices; users confirm if the numbers match. Provides strong protection against MITM.
- **Passkey Entry:** One device displays a passkey, and the other device requires manual entry. Secure but requires user input.
- **LE Secure Connections:** Introduced in Bluetooth 4.2. Uses Elliptic Curve Diffie-Hellman (ECDH) for key exchange and offers strong encryption.

Despite the availability of secure pairing options, many consumer-grade devices—particularly audio devices—still use the Just Works method, prioritizing ease of use over security. This creates a potential attack surface for unauthorized access and command injection.

3.3 Bluetooth Vulnerabilities

Bluetooth has several versions and profiles, each with differing levels of security. Bluetooth Classic (BR/EDR) and Bluetooth Low Energy (BLE) operate under different pairing mechanisms and security models. Common vulnerabilities include:

- **Just Works pairing:** Used when devices lack input/output capabilities. No authentication or encryption.
- **Legacy Pairing (pre-2.1):** Uses fixed PIN codes, often default or predictable.
- **Man-in-the-Middle (MITM) attacks:** Due to weak authentication.
- **Passive Eavesdropping:** Particularly in older versions without encryption.

Bluetooth 4.2 introduced LE Secure Connections using Elliptic Curve Diffie-Hellman (ECDH), but many devices still operate in Security Mode 1 (non-authenticated) for convenience.

3.4 AI Voice Synthesis

Modern AI speech synthesis tools such as Tacotron 2, WaveGlow, ESPnet, and Coqui TTS have significantly advanced. These models can be fine-tuned using only 5–10 minutes of voice data and reproduce intonation, accent, and emotion. This capability introduces a new social engineering vector: voice impersonation attacks.

Voice-based authentication systems are vulnerable when they rely solely on waveform matching, lacking biometric or multi-factor checks. Attackers can now realistically simulate voice inputs that pass traditional checks in voice-controlled systems.

4. Methodology

Bluetooth Attack Workflow

Device Discovery:

Used blueutil and system_profiler SPBluetoothDataType on macOS to identify active Bluetooth devices.

Collected MAC addresses and service descriptors.

Connection Process:

Used blueutil --connect <MAC> to connect directly.

Observed that no authentication was required, and the connection was auto accepted.

Audio Injection:

Utilized SwitchAudioSource to route system audio to target Bluetooth device.

Played MP3 payload using afplay.

Disconnection:

blueutil --disconnect <MAC> used to terminate connection and remove traces.

AI Voice Synthesis Workflow

Sample Collection:

Scraped publicly available recordings of the target's voice.

Cleaned and preprocessed audio (normalization, background noise reduction).

Model Training:

Trained Coqui TTS using a GPU instance on Google Colab.

Output synthetic audio samples and validated voice fidelity.

Command Scripting:

Created context-specific audio commands like "Unlock the door" or "Turn off security system".

Payload Packaging:

Exported final audio as MP3 for transmission to target Bluetooth device.

5. Project Execution

The attack was executed as follows:

A bash script was created to automate device scanning, connection, audio rerouting, playback, and disconnection.

A simulated brute-force Python script was run to model how an attacker could rapidly iterate through 4-digit PINs (0000 to 9999).

The audio payload (AI-generated) was successfully played on the target device.

Script modules included:

blueutil (for connection management)

SwitchAudioSource (for output rerouting)

afplay (for audio playback)

Python time-based loop (to simulate PIN cycling)

6. Attack Scenario

Environment Setup:

Target device: Bluetooth 5.0 earbuds configured with default pairing behavior.

Host system: macOS with native Bluetooth stack and CLI utilities.

Attack Steps:

Reconnaissance: Identified the device and obtained MAC address.

PIN Attack Modeling: Simulated PIN attack to show timing and feasibility.

Connection: Auto-accepted due to Just Works pairing.

Payload: Injected malicious AI audio command.

Execution: Command processed by smart assistant.

Cleanup: Disconnected, cleared history/logs.

7. Technical Analysis and Bluetooth Protocol Testing
Version Analysis:
Target device exhibits behavior consistent with Bluetooth 5.0 BR/EDR, which supports A2DP audio.
Modern devices using Bluetooth 5.2 offer stronger authentication but are less common in mid-tier earbuds.
Protocol Stack Details:
L2CAP: Handles segmentation and multiplexing.
RFCOMM: Provides serial port emulation.
SDP: Service discovery.
A2DP: High-quality audio stream.
HFP: Hands-free control (not used in this attack).
Pairing Mode:
Detected pairing mode: Just Works (no authentication, no user approval).
No fallback to PIN entry or numeric comparison.
Security Model:
Security Mode 1, Level 1: No authentication or encryption.
Vulnerable to passive MITM and eavesdropping.
Success Factors:
Target device accepted connections without interaction.
Audio commands played in real time.
Voice command successfully interpreted by assistant.

8. Results and Analysis
The experiment demonstrated that:
AI-generated voice commands can convincingly mimic a real user.
Bluetooth audio devices with weak pairing models accept connections without user input.
These devices can be abused as a "command injection relay" to indirectly control smart home systems.
The Python brute-force simulator showed that all 10,000 PIN combinations could be theoretically tested in under 5 minutes with basic optimization.

9. Ethical and Legal Considerations
Tests were conducted in a closed, controlled environment.
All devices were personal, and no third-party systems were accessed.
Purpose of this work is to raise awareness and propose defenses, not exploit real systems.
Ethical guidelines for responsible disclosure and research were followed.

10. Mitigation Strategies
Bluetooth-Level Protections:
Enforce LE Secure Connections.
Require user confirmation for pairing.
Disable discoverability when not in use.
Voice Security Enhancements:
Use voiceprint biometrics instead of basic waveform matching.
Add multi-factor checks before executing critical commands.
Detect anomalies in speech cadence and accent.
Awareness and Policy:
Educate users on safe Bluetooth usage.
Vendors should update firmware to enforce pairing protections.
Regulatory standards must be developed for voice-authenticated systems.

11. Conclusion
This project successfully demonstrates a novel and realistic attack that merges Bluetooth protocol weaknesses with AI-powered voice impersonation. The ability to deliver unauthorized commands through an audio channel opens serious concerns for the future of smart home security. As AI voice synthesis and wireless communication continue to evolve, so must our security paradigms. Through protocol analysis, proof-of-concept implementation, and ethical experimentation, we hope to highlight the urgency of improving authentication standards in both hardware and software.

12. References
IEEE Xplore. (2020). Bluetooth Security: Vulnerabilities and Mitigation Techniques.
IEEE Xplore. (2021). Voice Synthesis and its Implications for Security and Privacy.
Bluetooth SIG. (2023). Core Specification v5.3 and Security Enhancements.
Coqui TTS Documentation. (2024). AI Voice Synthesis Framework.
Apple Developer Tools. (2024). Blueutil and macOS Bluetooth Stack APIs.